

A Risk Scoring Framework for Critical Infrastructure of Decentralized Finance (DeFi)

Sanidhay Arora, Yingjiu Li, Yebo Feng, Jiahua Xu

PII: S2096-7209(26)00058-8
DOI: <https://doi.org/10.1016/j.bcra.2026.100496>
Reference: BCRA 100496



To appear in: *Blockchain: Research and Applications*

Received date: 3 June 2025
Revised date: 31 March 2026
Accepted date: 14 May 2026

Please cite this article as: Sanidhay Arora, Yingjiu Li, Yebo Feng, Jiahua Xu, A Risk Scoring Framework for Critical Infrastructure of Decentralized Finance (DeFi), *Blockchain: Research and Applications* (2026), doi: <https://doi.org/10.1016/j.bcra.2026.100496>

This is a PDF of an article that has undergone enhancements after acceptance, such as the addition of a cover page and metadata, and formatting for readability. This version will undergo additional copyediting, typesetting and review before it is published in its final form. As such, this version is no longer the Accepted Manuscript, but it is not yet the definitive Version of Record; we are providing this early version to give early visibility of the article. Please note that Elsevier's sharing policy for the Published Journal Article applies to this version, see: <https://www.elsevier.com/about/policies-and-standards/sharing#4-published-journal-article>. Please also note that, during the production process, errors may be discovered which could affect the content, and all legal disclaimers that apply to the journal pertain.

© 2026 Published by Elsevier Ltd on behalf of Zhejiang University Press.
This is an open access article under the CC BY-NC-ND license
(<http://creativecommons.org/licenses/by-nc-nd/4.0/>)

A Risk Scoring Framework for Critical Infrastructure of Decentralized Finance (DeFi)

Sanidhay Arora^a, Yingjiu Li^a, Yebo Feng^{b,d} and Jiahua Xu^{c,d}

^aDepartment of Computer Science, University of Oregon, Eugene, Oregon, USA

^bCollege of Computing and Data Science, Nanyang Technological University, Singapore

^cCentre for Blockchain Technologies, University College London, London, UK

^dExponential Science Foundation, Lugano, Switzerland

ARTICLE INFO

Keywords:

Blockchain

Decentralized Finance (DeFi)

Smart contract vulnerability

ABSTRACT

Decentralized Finance (DeFi) offers open and permissionless financial services, but its core infrastructure remains exposed to serious security failures. Representative infrastructure classes such as decentralized exchanges (DEXs), protocols for loanable funds (PLFs), and cross-chain bridges matter because failures can propagate widely.

This work presents a layered and empirically grounded framework for DeFi vulnerability prioritization. We analyze 558 exploit incidents from 2021–2025 and trace their mechanisms, vulnerabilities, and threat vectors across representative DeFi infrastructure classes. We introduce three complementary components: (1) a Risk Priority Number (RPN) used as an interpretable FMEA-style baseline for attack ranking, (2) an Adversarial Feasibility Score (AFS) that captures exploit feasibility from mapped adversarial-trait prevalence and accessibility, and (3) a Vulnerability-Centric Risk Score (VRS) defined as a structured priority ranking combining empirical likelihood, absolute economic severity, and attacker feasibility. The main validated model uses median per-incident USD loss as a consistent severity signal across the full incident dataset. Temporal validation shows that the structured vulnerability-priority model outperforms the multiplicative baseline and improves on the empirical base rank across both temporal holdouts and both future targets. The resulting framework provides an auditable remediation ordering for protocol developers, auditors, and risk managers.

1. Introduction

Decentralized Finance (DeFi) enables open and composable financial services through smart contracts on public blockchains [1]. Representative infrastructure classes such as decentralized exchanges (DEXs), protocols for loanable funds (PLFs), and cross-chain bridges anchor much of this activity. Their composability also creates layered attack surfaces. A weakness in one component can propagate across integrated modules and expose a wider part of the ecosystem. Recent exploits illustrate this pattern: attackers have chained vulnerabilities across smart contracts, price oracles, governance mechanisms, and bridge logic to amplify impact. Werner et al. (2022) underscore the difficulty of securing such interdependent DeFi components [2]. Bekemeier (2022) similarly highlights fragility in interconnected DeFi systems [3].

Several studies have examined specific DeFi vulnerabilities in isolation. Li et al. (2022) cataloged vulnerabilities across blockchain layers, from consensus to application [4]. Zhou et al. (2023) proposed a taxonomy of common DeFi attack vectors [5]. Other works focus on detecting or preventing particular exploit types. Chaliasos et al. (2023) evaluated tools for identifying prevalent smart contract flaws [6]. Ding et al. (2024) developed concolic analysis techniques to hunt logic vulnerabilities in DeFi protocols [7]. These efforts have advanced understanding of threats such as reentrancy and price manipulation. However, prior research still lacks a validated framework for prioritizing DeFi vulnerability classes over a labeled exploit corpus. Many studies remain attack-specific or descriptive. Others use ordinal score combinations without clear prospective validation or clear separation between observed severity and exploit feasibility. In practice, multi-vector incidents such as flash-loan-assisted governance takeovers show why attacker capabilities and cross-domain tactics need to be modeled explicitly [8].

There is therefore a need for quantitative models that identify which vulnerability classes should be prioritized and that justify their ranking rules empirically. In this paper, we present a multi-layer, data-driven framework for DeFi vulnerability prioritization. We compile a dataset of 558 curated DeFi exploit incidents from 2021–2025, seeded

from the DeFiHackLabs repository maintained by SunWeb3Sec [9] and supplemented with public incident reporting and archives such as *rekt.news* [10] and the SlowMist Hacked archive [11]. Using this data, we analyze vulnerability prevalence and impact across technical, economic, and governance layers. We then introduce three complementary scoring components:

- **Risk Priority Number (RPN):** An FMEA-style baseline that ranks attack types by coarse severity and likelihood levels.
- **Adversarial Feasibility Score (AFS):** An attacker-centric scalar feasibility score derived from mapped adversarial-trait prevalence and accessibility.
- **Vulnerability-Centric Risk Score (VRS):** A structured vulnerability-priority ranking that combines explicit empirical likelihood, a robust severity proxy, and attacker feasibility.

These components address three limitations of prior approaches. First, they distinguish recurrence, severity, and exploit feasibility instead of collapsing them into a single opaque product. Second, they incorporate attacker feasibility by mapping vulnerabilities to concrete adversarial traits and resource requirements. Third, they are evaluated prospectively on temporal train/test splits rather than being justified only by in-sample reconstruction. In the main ranking model, severity is measured as absolute economic loss rather than protocol-size-normalized loss. This is a substantive choice: absolute loss captures realized value destruction and is measured consistently across the full incident dataset. By contrast, TVL-normalized severity is informative for relative or existential protocol impact, but historical denominators are not recoverable or economically comparable for many incidents. We therefore treat TVL-normalized severity as a supplementary robustness dimension rather than a prerequisite for the core validated model.

The three components also operate at deliberately different units of analysis. RPN is attack-type-centric because attack classes are directly observable manifestations that support ecosystem-level monitoring and provide a familiar FMEA-style benchmark, even though that multiplicative baseline is not the paper's strongest predictive form. VRS is vulnerability-centric because mitigation is ultimately applied to remediable root causes rather than to high-level attack manifestations. This distinction is important in DeFi, where a single attack type may arise from multiple underlying vulnerabilities, and a single vulnerability class may surface through different attack manifestations depending on protocol context.

Our contributions are threefold. First, we adapt a layered, infrastructure-oriented taxonomy for DeFi risk prioritization, spanning the smart contract, protocol logic, auxiliary service, and consensus layers while emphasizing DeFi-native mechanism risks such as liquidity dependence, oracle reliance, governance manipulability, composability, and cross-chain settlement. Second, we construct a capability-aware threat model that captures real adversarial constraints and resources in the DeFi context. Third, we introduce and evaluate three interpretable scoring components (RPN, AFS, and VRS), and show through temporal validation that a likelihood-first vulnerability-priority method, refined by adversarial feasibility, outperforms multiplicative baselines and improves on the empirical base rank across both holdouts. Direct scalar alternatives remain competitive on some targets, and simple frequency-only ranking remains a strong comparator on the loss target in the 2025 holdout. Overall, our analysis shows that low-frequency vulnerabilities such as cross-chain settlement failures or reliance on off-chain oracles can still warrant high remediation priority.

The remainder of this paper is structured as follows. Section 2 reviews DeFi's core infrastructure components and summarizes prior work on technical, economic, and governance risks. Section 3 introduces our attack taxonomy and layered threat model. Section 4 presents the classification of vulnerabilities according to this model. We then analyze statistical trends and frequency-impact data from the 558 incidents in Section 5. Section 6 formalizes the scoring framework and evaluates it on temporal holdouts. Section 7 discusses methodological implications and future research directions in DeFi. Finally, Section 8 concludes with a summary of contributions.

2. Background and Related Work

This section outlines the infrastructure scope used in the paper and reviews the most relevant security literature. We focus on smart contract vulnerabilities, economic exploitation, governance manipulation, and protocol dependence.

2.1. Overview of DeFi's Critical Infrastructure

Decentralized Finance (DeFi) enables financial services through smart contracts deployed on permissionless blockchains, without centralized intermediaries [1, 12]. We focus on three representative infrastructure classes:

- **Decentralized Exchanges (DEXs):** DEXs facilitate peer-to-peer trading of digital assets via automated market makers (AMMs), without centralized order books. Notable platforms include Uniswap, Curve, and SushiSwap.
- **Protocols for Loanable Funds (PLFs):** PLFs such as Aave, Compound, and MakerDAO enable lending and borrowing by using smart contracts to enforce collateral, interest rates, and liquidation rules [13].
- **Cross-chain Bridges (Bridges):** Bridges enable interoperability across otherwise disconnected blockchain networks. These systems allow users to transfer assets or data between heterogeneous chains such as Ethereum, BNB Chain, or Solana.

We focus on DEXs, PLFs, and bridges as representative foundational infrastructure classes rather than as an exhaustive partition of all DeFi applications. These three categories are selected because they underpin core ecosystem functions: trading and price discovery, collateralized credit and leverage, and interoperability across chains. Many downstream applications, including yield aggregators, structured products, stablecoin systems, and derivatives protocols, depend directly or indirectly on one or more of these primitives. Our scope is therefore infrastructure-centric: we prioritize protocol classes whose compromise can propagate losses across a broad segment of the DeFi stack.

We do not list oracles as a separate top-level infrastructure class because they are modeled as critical auxiliary dependencies that cut across multiple application families, especially DEXs and PLFs, rather than as a standalone DeFi application category. This is why oracle failures enter the later taxonomy through the auxiliary-service and protocol-logic layers instead of through a fourth primary infrastructure class.

These platforms are central to DeFi and are frequently targeted. Bridges expand composability and liquidity across ecosystems, but they also add new attack surfaces. Their architecture combines on-chain and off-chain components and can fail in more than one way. Securing these infrastructure classes remains a central challenge for DeFi [3].

2.2. Related Work

Research in DeFi security has grown rapidly. We organize the discussion around four domains and then contrast them with our framework.

Smart Contract Vulnerability Tools. Researchers have developed various tools to identify vulnerabilities in smart contracts. Chaliasos et al. [6] survey and evaluate multiple smart contract security analysis tools, highlighting differences in their detection capabilities. Advanced program analysis techniques have been adapted for DeFi: for example, Ding et al. [7] introduce a context-sensitive concolic verifier to hunt DeFi-specific vulnerabilities. Other systems focus on particular attack vectors. Chen et al. [14] synthesize flash loan exploits via counterexample-driven transactions. Wang et al. [15] and Wu et al. [16] propose methods to detect DeFi logic flaws and price manipulation attacks, respectively.

Governance and Oracle Exploits. DeFi relies on on-chain governance and external data oracles, which have emerged as critical attack surfaces. Flash loans have been used to manipulate price oracles and distort asset valuations for profit [8]. Zhao et al. [17] provide a comprehensive review of oracle design, vulnerabilities, and mitigation strategies, while Deng et al. [18] propose defenses against malicious oracle deviations. Governance mechanisms can also be subverted. In so-called "flash governance" attacks, an adversary temporarily amasses voting power (e.g., via borrowed tokens) to pass malicious proposals, as noted by recent systematizations [2, 5]. Such attacks undermine decentralized decision-making within protocols.

Systemic Risk and Composability. The composability of DeFi, often described as "money Lego," adds complexity and potential systemic risk. Interdependence means a failure or exploit in one protocol can cascade into others through financial links [3, 19]. Carter and Jeng [19] discuss this paradox of DeFi: greater decentralization can introduce new systemic vulnerabilities. Bekemeier et al. [3] provide a conceptual framework for analyzing systemic risk in interconnected DeFi ecosystems. Empirically, Kitzler et al. [20] show that the complex network of cross-protocol interactions may amplify fragility if not properly managed.

Risk Quantification Models. Several works model and quantify specific financial risks in DeFi protocols. Klages-Mundt et al. [21] develop risk-based models for stablecoins, evaluating how design choices affect stability and peg robustness. Wang et al. [22] quantify on-chain leverage risk, showing how under-collateralized lending platforms increase exposure to cascading liquidations. Qin et al. [23] analyze large-scale DeFi liquidation data to measure instabilities in lending protocols' liquidation mechanisms. In addition, formal metrics have been proposed for automated market maker losses: Millionis et al. [24] derive a closed-form measure for impermanent loss risk facing liquidity providers.

More generally, the security and reliability literature already contains several quantitative scoring traditions that matter for our design choices, even when they are not DeFi-specific. Classic Failure Modes and Effects Analysis (FMEA) commonly combines severity, occurrence, and detection through the Risk Priority Number (RPN) [25, 26], while the Common Vulnerability Scoring System (CVSS) provides a bounded vulnerability-severity framework centered on exploitability and impact [27, 28]. Closer to our setting, Kaur et al. [29] use fuzzy-AHP to rank broad DeFi risk categories from expert judgments, Bertomeu et al. [30] derive protocol-level fragility metrics for DeFi lending from deposits and borrowings, and Babel et al. [31] measure cryptoeconomic security by searching for extractable-value strategies in concrete contract environments. These are important quantitative references, but they target different analytical objects from ours: generic failure modes, generic software vulnerabilities, broad ecosystem risk categories, protocol-level financial fragility, or contract-specific transaction environments, rather than incident-derived vulnerability classes validated on future exploit data.

Datasets and Taxonomies. Broader surveys and taxonomies of DeFi security have emerged to organize knowledge of vulnerabilities and attacks. Li et al. [4] catalog known vulnerabilities across blockchain layers, and Li et al. [32] review recent DeFi attack trends and defenses. Werner et al. [2] and Gogol et al. [33] provide systematizations of DeFi protocols and their risks, while Zhou et al. [5] focus on DeFi attack vectors. Community databases complement these academic taxonomies by documenting real-world incidents. Building on these public sources, our reconstructed dataset contains 558 DeFi exploit incidents from 2021 through 2025.

2.3. Gaps and Motivation

Although prior research has advanced our understanding of DeFi vulnerabilities, much of it remains attack-specific, taxonomy-oriented, or focused on a different unit of analysis [5, 34]. Attacker prerequisites are rarely made explicit in a way that feeds into vulnerability prioritization. Many works organize known risks without turning them into reproducible class-level ranking rules [6, 15]. Multi-vector attacks, such as flash-loan-based governance takeovers, also show that technical, economic, and governance failures cannot always be studied in isolation [35, 36].

While taxonomies are useful foundations, most prior works stop short of providing a vulnerability-prioritization model on top of an audited exploit corpus. Existing quantitative frameworks either operate at a different level of abstraction, such as broad risk-category weighting, protocol-level financial fragility, or transaction-environment strategy search, or they rely on generic scoring traditions whose occurrence terms are heuristic, software-centric, or otherwise detached from incident-derived recurrence in DeFi exploit data. There therefore remains a need for a model that can systematically prioritize remediable vulnerability classes using incident-derived recurrence, incident-derived economic severity, and explicit adversarial prerequisites. This gap motivates our integrated approach, which combines adversarial modeling and large-scale empirical analysis with quantitative scoring components.

2.4. Contribution

This paper addresses these limitations with a layered and empirically grounded framework for DeFi vulnerability prioritization. It builds on a reconstructed dataset of 558 DeFi exploit incidents from 2021–2025 and combines descriptive analysis with temporal validation. The framework uses three components: an interpretable RPN baseline, an adversarial feasibility score, and a structured vulnerability-priority ranking. Together, they provide a more explicit basis for prioritizing remediable vulnerability classes in DeFi infrastructure.

3. Threat Model

DeFi operates in a permissionless setting where any actor can interact directly with smart contracts that control financial value. We therefore use a trait-based threat model rather than a single attacker profile. The model records adversarial capabilities and knowledge that matter for exploit feasibility. These traits later inform the AFS and VRS constructions in Section 6.

The threat model is intentionally compact. It covers the technical, financial, and privileged conditions that appear repeatedly in major DeFi exploits. These conditions often combine in practice. Contract flaws, market abuse, governance weakness, leaked credentials, and ordering control may all appear in the same exploit path.

For notation, let $\mathbb{A}$ denote an attacker targeting representative infrastructure classes such as DEXs, PLFs, and bridges. The capabilities and knowledge available to $\mathbb{A}$ determine the practical feasibility of exploitation.

3.1. Adversarial Capabilities

The following capabilities may be possessed by an adversary. A single adversary need not possess all of them.

- AC₁ Technical Execution:** $\mathbb{A}$ can understand protocol logic and translate that knowledge into executable exploit code or transaction sequences.
- AC₂ Computational or Validator Control:** $\mathbb{A}$ has exceptional computational or validator-level resources that can influence ordering, inclusion, or specialized attacks such as 51% attacks.
- AC₃ Financial Resources:** $\mathbb{A}$ can mobilize substantial capital for flash-loan attacks, market manipulation, or liquidity-based influence.
- AC₄ Network or Privileged Control:** $\mathbb{A}$ can exercise scarce network-level or privileged control, including multisig misuse or other protected access.
- AC₅ Adaptive Execution:** $\mathbb{A}$ can compose multiple protocol interactions and adjust attack steps during execution.

3.2. Adversarial Knowledge

The following summarizes the types of knowledge an adversary may possess. A single adversary need not possess all of them.

- AK₁ Protocol Specifications / Public Documentation:** $\mathbb{A}$ understands public documentation, source code, and other open materials well enough to identify design flaws or vulnerabilities.
- AK₂ Network State and Transactions:** $\mathbb{A}$ can observe public on-chain state, including transactions, balances, and contract states, and use that visibility for timing and execution.
- AK₃ Economic Dynamics:** $\mathbb{A}$ understands liquidity, pricing, interest-rate mechanics, and other economic rules that govern DEXs and PLFs.
- AK₄ Security Practices / Exploitation Knowledge:** $\mathbb{A}$ knows common exploit patterns, auditing practices, and recurring weaknesses in DeFi systems.
- AK₅ Governance Processes:** $\mathbb{A}$ understands how proposals are created, voted on, and executed, and can use that knowledge to influence governance outcomes.
- AK₆ Miner / Sequencer / Builder Knowledge:** $\mathbb{A}$ has access to pending transactions through private channels or early visibility into the ordering environment.
- AK₇ Insider Knowledge / Private Data:** $\mathbb{A}$ has access to privileged information such as oracle updates, early market data, or operator wallet credentials.

4. Vulnerabilities

DeFi systems consist of interdependent layers that govern contract execution, protocol logic, auxiliary services, and consensus. This section defines the layered vulnerability taxonomy used in the paper and the class-level mappings later used in AFS.

The taxonomy does not assume that every weakness is unique to DeFi. Instead, it combines general smart contract and blockchain security failures with mechanism-level risks that become especially important in DeFi infrastructure. The layered structure is therefore meant to support DeFi-focused prioritization, not to claim that every listed weakness originates only in DeFi.

Smart Contract Layer (SCL): The foundational logic and asset management of DeFi applications are handled in the Smart Contract Layer. Vulnerabilities at this layer stem from programming flaws or insecure design patterns.

- SCL₁ Reentrancy Conditions:** Recursive external calls before state updates allow repeated unauthorized transfers.
- SCL₂ Arithmetic Faults:** Integer overflows, underflows, or rounding errors compromise financial calculations and protocol correctness.
- SCL₃ Unchecked External Calls:** Failure to validate return values from external calls can lead to silent execution failures or malicious responses.

Table 1

Mapping of Vulnerabilities to Exploit-Enabling Adversarial Capabilities and Knowledge

Vulnerability	Exploit-Enabling Capabilities	Exploit-Enabling Knowledge
Reentrancy Conditions (SCL ₁)	AC ₁ , AC ₅	AK ₁ , AK ₂ , AK ₄ , AK ₆
Arithmetic Faults (SCL ₂)	AC ₁	AK ₁ , AK ₄
Unchecked External Calls (SCL ₃)	AC ₁	AK ₁ , AK ₄
Unsafe Delegatecall Use (SCL ₄)	AC ₁ , AC ₅	AK ₁ , AK ₄
Improper Access Control (SCL ₅)	AC ₁	AK ₁ , AK ₄
Oracle Trust Assumptions (PL ₁)	AC ₃ , AC ₅	AK ₂ , AK ₃ , AK ₆ , AK ₇
Liquidity Manipulation Susceptibility (PL ₂)	AC ₃ , AC ₄ , AC ₅	AK ₂ , AK ₃
Composability Risk (PL ₃)	AC ₁ , AC ₅	AK ₁ , AK ₃ , AK ₄ , AK ₇
Governance Design Flaws (PL ₄)	AC ₄ , AC ₅	AK ₃ , AK ₅
Cross-Chain State Verification Assumptions (PL ₅)	AC ₁ , AC ₅	AK ₂ , AK ₃ , AK ₆ , AK ₇
Off-Chain Oracle Dependence (ASL ₁)	AC ₃ , AC ₅	AK ₂ , AK ₃ , AK ₆ , AK ₇
Credential Exposure (ASL ₂)	AC ₄	AK ₇
Phishing-Prone Interfaces (ASL ₃)	AC ₅	AK ₇
Finality Assumption (CL ₁)	AC ₂ , AC ₄	AK ₂
Validator Censorship (CL ₂)	AC ₂	AK ₆
Transaction Reordering in Block Construction (CL ₃)	AC ₅	AK ₆

SCL₄ *Unsafe Delegatecall Use*: Improper use of `delegatecall` enables attacker-supplied logic, which may lead to hijacking contract execution.

SCL₅ *Improper Access Control*: Misconfigured roles or permission checks enable unauthorized access to sensitive functions or funds.

Protocol Layer (PL): This layer covers DeFi-native economic mechanisms, governance systems, interoperability assumptions, and incentive structures. These vulnerabilities stem from flawed assumptions or configurations in governance, price feeds, liquidity sensitivity, composability, and cross-chain state verification.

PL₁ *Oracle Trust Assumptions*: Overreliance on manipulable or delayed external price feeds compromises lending, liquidation, or swap logic.

PL₂ *Liquidity Manipulation Susceptibility*: Protocols that fail to account for instant liquidity manipulation via flash loans become susceptible to atomic arbitrage attacks.

PL₃ *Composability Risk*: Trust assumptions in integrated third-party contracts or protocol dependencies can introduce vulnerabilities beyond the developer's direct control and propagate failures across connected DeFi applications.

PL₄ *Governance Design Flaws*: Weak quorum, timelock, voting-safeguard, or execution-control design in blockchain governance can let attackers capture proposal execution through temporary token holdings or concentrated governance authority.

PL₅ *Cross-Chain State Verification Assumptions*: Bridge and interoperability mechanisms that weakly validate remote state, signatures, relay messages, or proof assumptions can permit unauthorized minting, release, replay, or transfer of assets across chains.

Auxiliary Service Layer (ASL): This layer includes components external to the protocol's smart contract but essential for user interaction and cross-protocol functionality. Interfaces and off-chain systems such as APIs, key infrastructure, and oracles create critical external dependencies.

ASL₁ *Off-Chain Oracle Dependence*: Reliance on external data sources introduces a trust dependency that, if unverified or delayed, exposes the protocol to adversarially controlled inputs.

ASL₂ *Credential Exposure*: Mismanaged or stolen private keys may lead to full compromise of admin functions or fund withdrawals.

Table 2

Canonical Mapping of Attack Types to Their Primary Exploited Vulnerabilities

Attack Type	Vulnerability
Flash Loan Attacks ($\mathcal{AT}_1$)	PL ₂ , PL ₁
Reentrancy Attacks ($\mathcal{AT}_2$)	SCL ₁
Contract Logic Exploits ($\mathcal{AT}_3$)	SCL ₂ , SCL ₅
Oracle Manipulation ($\mathcal{AT}_4$)	PL ₁ , ASL ₁
Governance Exploits ($\mathcal{AT}_5$)	PL ₄
External Call Abuse ($\mathcal{AT}_6$)	SCL ₃ , SCL ₄
Key Compromise ($\mathcal{AT}_7$)	ASL ₂
Bridge Exploits ($\mathcal{AT}_8$)	PL ₅
Phishing Attacks ($\mathcal{AT}_9$)	ASL ₃
MEV Attacks ($\mathcal{AT}_{10}$)	CL ₃
Composability Abuse ($\mathcal{AT}_{11}$)	PL ₃

ASL₃ *Phishing-Prone Interfaces*: Malicious web UIs or apps may trick users into signing arbitrary transactions or disclosing secrets.

Consensus Layer (CL): The consensus layer forms the security foundation for protocol operations. Vulnerabilities in this layer undermine transaction finality and can be exploited for censorship or reordering.

CL₁ *Finality Assumption*: Protocols assume that transactions, once confirmed, are immutable and irreversible; failure to account for potential chain reorganizations or delayed finality introduces risk of state inconsistency.

CL₂ *Validator Censorship*: Validators may selectively include or exclude transactions, breaking protocol liveness or fairness.

CL₃ *Transaction Reordering in Block Construction*: Block constructors may reorder transactions to allow front-run or back-run.

Table 1 summarizes the adversarial capabilities and knowledge conditions most commonly implicated in exploitation of each vulnerability class. These mappings are intentionally conservative. They identify conditions that matter for feasibility analysis, without claiming that every incident must involve every listed trait in the same way. Real-world exploits often combine vulnerabilities across layers. The taxonomy contains 16 vulnerability classes, but only 14 appear in the included 2021–2025 incident corpus. *Finality Assumption* (CL₁) and *Validator Censorship* (CL₂) remain conceptually important but do not appear in the empirical scoring tables because no included incidents mapped to them. In the next section, we analyze the included 2021–2025 dataset of 558 incidents and later use temporal holdouts from that same dataset for prospective validation in Section 6.

5. Attack Analysis

To support the vulnerability taxonomy from Section 4, we analyze the full included 2021–2025 dataset of 558 DeFi exploit incidents. Each attack is categorized by exploited vulnerability and affected layers. This analysis quantifies attack frequency and severity and motivates the scoring models introduced in Section 6. Section 6 then evaluates those models on temporal holdouts drawn from the same reconstructed dataset.

5.1. Attack Taxonomy and Vulnerability Mapping

We define 11 distinct attack classes that reflect real-world adversarial strategies and align them with the vulnerabilities presented in Section 4. These classes span logic flaws, economic manipulation, governance exploitation, and infrastructure-level compromise. For compact reference in the empirical figures, we denote them as $\mathcal{AT}_1$ through $\mathcal{AT}_{11}$. Table 2 shows the canonical mapping between these attack families and the primary vulnerability classes they most commonly express. At the incident level, audited labels can deviate from this anchor mapping when multi-vector cases or case-specific root-cause review indicate a different dominant vulnerability. The 11 attack classes are described below:

- **Flash Loan Attacks ($\mathcal{AT}_1$):** Adversaries leverage flash loans to momentarily access large liquidity and manipulate protocol invariants, often targeting oracles or governance mechanisms within the same transaction.
- **Reentrancy Attacks ($\mathcal{AT}_2$):** Attackers exploit improperly managed external function calls to repeatedly re-enter a contract, bypassing state updates and enabling unauthorized withdrawals.
- **Contract Logic Exploits ($\mathcal{AT}_3$):** Adversaries identify and exploit arithmetic faults, initialization errors, or flawed conditional logic to gain illicit access to funds or disrupt protocol functionality.
- **Oracle Manipulation ($\mathcal{AT}_4$):** Attackers manipulate both on-chain and off-chain price or data feeds to inject false market information. This manipulation enables arbitrage, mispricing, or fraudulent borrowing.
- **Governance Exploits ($\mathcal{AT}_5$):** Adversaries subvert decentralized governance processes by acquiring temporary voting power (e.g., via flash loans) or by exploiting poorly designed quorum or proposal mechanisms.
- **External Call Abuse ($\mathcal{AT}_6$):** Attackers misuse unchecked external calls or unsafe `delegatecall` operations to execute arbitrary logic and hijack contract control flows.
- **Key Compromise ($\mathcal{AT}_7$):** Attackers obtain unauthorized access to privileged private keys, such as admin or multi-sig keys, and subsequently initiate asset transfers or administrative functions.
- **Bridge Exploits ($\mathcal{AT}_8$):** Adversaries compromise cross-chain bridges by exploiting weak cross-chain state verification, flawed message validation, or insecure mint/burn mechanisms, allowing unauthorized token creation, release, or withdrawals.
- **Phishing Attacks ($\mathcal{AT}_9$):** Adversaries design malicious interfaces or spoof transactions to deceive users into signing unsafe actions, thereby gaining unauthorized access to user funds.
- **MEV Attacks ($\mathcal{AT}_{10}$):** Block constructors exploit their control over transaction ordering to perform front-running, sandwich attacks, or block reordering to gain Maximum Extractable Value (MEV).
- **Composability Abuse ($\mathcal{AT}_{11}$):** Adversaries exploit interdependencies and implicit assumptions among integrated smart contracts or protocols, resulting in cascading vulnerabilities or unintended interactions without bridge-specific state validation necessarily being the point of failure.

We distinguish **Bridge Exploits** from **Composability Abuse** by the primary failure point. Bridge exploits refer to incidents whose core failure lies in cross-chain messaging, signature verification, validator or relayer assumptions, or mint/burn logic within dedicated bridge infrastructure. In our taxonomy, these failures map to *Cross-Chain State Verification Assumptions* (PL_5) rather than to the broader *Composability Risk* category. Composability abuse refers to failures caused by unsafe assumptions across integrated protocols or dependencies, even when no dedicated bridge is the immediate point of compromise.

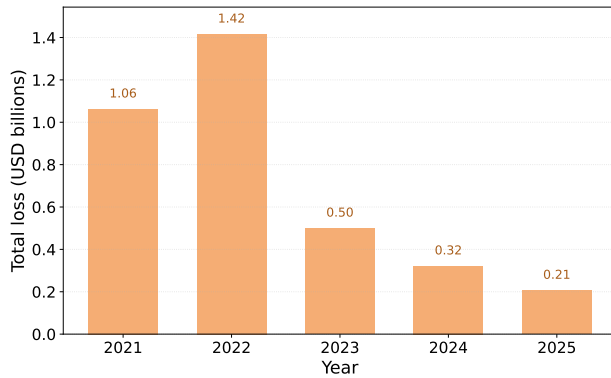
Multi-Vector Incidents. Many exploits combine multiple attack vectors across layers. For instance, flash loans (Protocol Layer) may enable oracle manipulation (Auxiliary Layer), which allows unauthorized withdrawals (Smart Contract Layer). Mango Markets and Beanstalk exemplify this behavior. Rather than listing "multi-vector" as a standalone class, we annotate exploits accordingly when two or more vulnerabilities are exploited in combination. This provides nuance without inflating the taxonomy.

Our taxonomy draws from prior surveys [2, 4, 34], incident repositories such as the DeFiHackLabs repository maintained by SunWeb3Sec [9], and the adversarial capability framework introduced in Section 3. The goal is not to enumerate every conceivable attack, but to capture representative vectors that recur across incidents, remain structurally distinct, and matter financially. This taxonomy therefore emphasizes DeFi-native mechanism risks, such as liquidity dependence, governance manipulability, composability, and cross-chain state transfer, while acknowledging that some lower-layer exploit primitives are shared with the broader smart contract ecosystem.

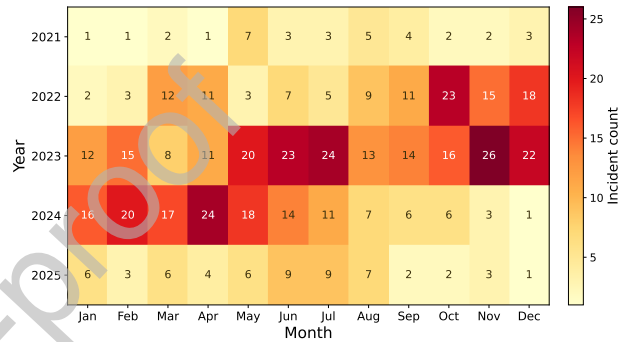
Table 3

Top 10 DeFi Exploits by Amount Lost in the Full Included 2021–2025 Dataset

Date	Protocol	Lost (USD)	Attack Label(s)
Mar 2022	Ronin Network	\$624M	Key Compromise
Aug 2021	Poly Network	\$611M	Contract Logic Exploits; Bridge Exploits
Mar 2023	Euler Finance	\$200M	Contract Logic Exploits
Apr 2022	Beanstalk	\$182M	Flash Loan Attacks; Governance Exploits
Aug 2022	Nomad Bridge	\$152M	Contract Logic Exploits; Bridge Exploits
Oct 2021	Cream Finance	\$130M	Flash Loan Attacks
Nov 2025	Balancer V2	\$120M	Contract Logic Exploits
Jun 2022	Harmony's Horizon Bridge	\$100M	Key Compromise
Feb 2023	BonqDAO	\$88M	Oracle Manipulation
Jan 2024	Orbit Chain	\$81M	Key Compromise



(a) Total losses (in USD billions) by year.



(b) Heatmap for monthly frequency of DeFi attacks.

Figure 1: Temporal overview of the full included 2021–2025 dataset. Panel (a) reports annual aggregate exploit losses in USD billions, and panel (b) reports the monthly incident-frequency heatmap across years.

5.2. Dataset Overview

To empirically support our vulnerability taxonomy and risk scoring framework, we curate a reconstructed dataset of 558 included DeFi exploit incidents spanning 2021 through 2025. Each attack is annotated with the protocol name (and type), date of occurrence, financial loss (in USD), and attack label(s). Section 6 then uses temporal holdouts within this dataset for out-of-sample validation.

The full included 2021–2025 dataset was compiled from widely used and publicly verifiable incident sources, led by the DeFiHackLabs repository maintained by SunWeb3Sec [9] and supplemented, where needed, with public exploit reporting and archives such as *rekt.news* incident reports [10] and the SlowMist Hacked archive [11]. These sources are maintained by established blockchain security communities that track incidents with details such as transaction hashes, attacker wallets, and post-mortem analyses. In our reconstruction workflow, the DeFiHackLabs repository serves as the primary source of record, while supplementary public reports and archives fill missing incidents or missing fields and document provenance when multiple public accounts exist. Duplicates, unverifiable reports, and out-of-scope cases were excluded under the curation rules described in the dataset protocol. Incident inclusion and labeling followed a mixed workflow. Protocol identity, inclusion/exclusion decisions, and many high-loss or taxonomy-sensitive attack/vulnerability assignments were curator-reviewed under the written protocol, while normalization, deduplication checks, and downstream aggregation for scoring were script-assisted. The resulting corpus combines targeted row-level review with seed-derived cases that remain source-documented but were not reconciled to identical depth across all 558 incidents.

We summarize the ten most financially severe included incidents in Table 3. The table reports the incident date, protocol name, attack label(s), and amount lost in USD. This view highlights the failures that dominate the loss distribution.

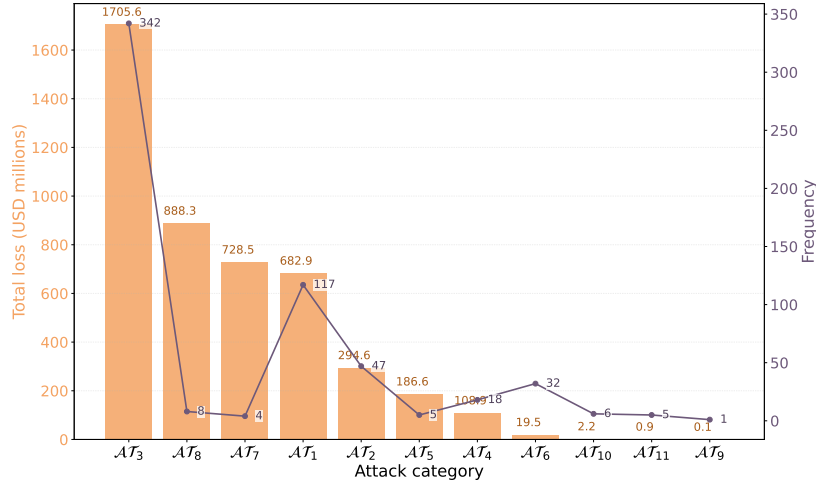


Figure 2: Attack-category frequency and total loss for the full included 2021–2025 dataset. Orange bars report aggregate loss in USD millions, purple markers report incident counts, the x-axis uses the compact attack-type notations $\mathcal{AT}_1$ through $\mathcal{AT}_{11}$ and categories are ordered from left to right by descending total loss.

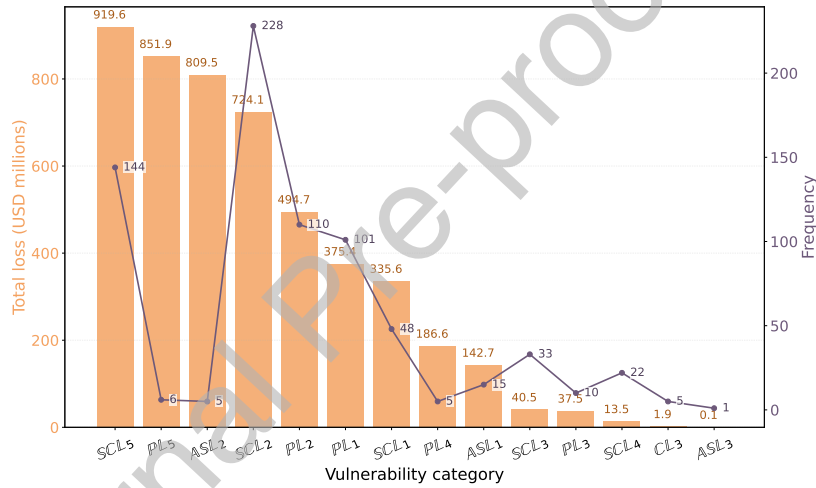


Figure 3: Vulnerability-category frequency and total loss for the full included 2021–2025 dataset. Orange bars report aggregate loss in USD millions, purple markers report incident counts. The x-axis uses the vulnerability notations directly and categories are ordered from left to right by descending total loss.

For the temporal overview and the category-level distribution figures below, we use the full included 2021–2025 dataset so that these aggregate views reflect the most current version of the incident dataset used in this study.

Trend analysis. Figure 1(a) presents the annualized losses (in USD) caused by DeFi exploits across the full included 2021–2025 dataset. Aggregate losses peak in 2022 at roughly \$1.42 billion, remain high in 2021 at about \$1.06 billion, and then decline across 2023–2025 while staying materially nonzero. Figure 1(b) shows the monthly heatmap of incident frequency across the same full period. The densest clusters appear in late 2022 and mid-to-late 2023, with sustained but lower activity continuing through 2024 and 2025. Together, these panels show that extreme loss concentration and incident frequency do not peak in the same months or years, reinforcing the need to track both dimensions explicitly.

Figure 2 shows the total financial loss (in millions USD) and frequency associated with each attack type across the full included 2021–2025 dataset. Contract logic exploits dominate both frequency and cumulative loss, accounting for 342 incidents and roughly \$1.71 billion in aggregate losses. Bridge exploits are far less frequent, with only 8 incidents, but they remain the second-largest loss vector at roughly \$888 million, reflecting the catastrophic severity of successful cross-chain failures. Key-compromise incidents are similarly rare, with only 4 recorded cases, yet they account for about \$729 million in losses. Flash-loan attacks remain the most recurrent economic manipulation pattern,

with 117 incidents and roughly \$683 million in aggregate loss. The divergence between frequency and impact across attack types underscores a key insight: not all common attacks are the most dangerous, and not all severe attacks are frequent.

Figure 3 illustrates the financial losses and exploitation frequencies of vulnerabilities across the full included 2021–2025 dataset, revealing several important patterns. Arithmetic faults (SCL_2) are the most frequent vulnerability class with 228 incidents, while improper access control (SCL_5) produces the largest cumulative loss at roughly \$920 million across 144 incidents. The bridge-specific *Cross-Chain State Verification Assumptions* category (PL_5) appears only 6 times, yet it accounts for roughly \$852 million in losses, confirming that bridge-state failures are rare but catastrophic. Credential exposure (ASL_2) is similarly rare, with only 5 incidents, but it still contributes roughly \$810 million in cumulative loss because successful key compromise can be existential. Among the more recurrent protocol-layer risks, liquidity manipulation susceptibility (PL_2) and oracle trust assumptions (PL_1) account for 110 and 101 incidents, respectively, with roughly \$495 million and \$375 million in aggregate losses. Reentrancy conditions (SCL_1) remain a persistent smart-contract threat with 48 incidents and about \$336 million in loss. Overall, the figure shows that frequency and severity do not move together mechanically: some vulnerabilities recur persistently, while others occur rarely but fail catastrophically when exploited.

Cross-Layer Attack Composition. Many major exploits span more than one infrastructure layer, and cross-layer attack chains appear repeatedly in high-loss incidents. For example, flash loans (Protocol Layer) were often used to enable price manipulation (Auxiliary Layer), which in turn allowed unauthorized state transitions (Smart Contract Layer) [37]. Incidents such as Mango Markets, Euler Finance, and Beanstalk show how exploit paths can combine technical flaws, economic manipulation, and timing around governance mechanics. These patterns motivate a scoring framework that does not rely on attack frequency alone. We incorporate that consideration in the Adversarial Feasibility Score (AFS) methodology introduced in Section 6.

Insight and Risk Prioritization. Our findings indicate three patterns. First, economic exploit paths account for many high-loss incidents. Second, composability enables layered attacks that can evade isolated code review. Third, many damaging incidents depend on timing, protocol knowledge, and economic modeling rather than on code flaws alone. Together, these observations motivate the risk quantification models introduced in the next section.

6. Risk Quantification and Scoring

With the vulnerability taxonomy and exploit dataset established, we next define how risks are prioritized. We separate three constructs that are often conflated in DeFi risk discussions: observed recurrence, observed financial severity, and exploit feasibility. The main analysis uses the reconstructed 2021–2025 incident dataset (558 included incidents) and relies on quantities that are available consistently across that dataset.

In this paper, the main severity notion is *absolute economic severity*. We operationalize it with median per-incident USD loss at the category level. Large absolute losses matter even when they are not a large fraction of protocol TVL because they reflect realized value destruction and the practical scale of incidents that auditors, developers, and risk managers must triage. We use the median rather than the mean because DeFi loss distributions are highly heavy-tailed. A few catastrophic incidents can dominate averages and make class-level severity unstable under single-incident revisions. The median better captures the typical conditional severity of a vulnerability class.

6.1. Design Principles and Validation Protocol

A defensible DeFi prioritization rule should satisfy five properties. First, *construct separation*: recurrence, severity, and adversarial attainability should not be conflated into a single unexplained quantity. Second, *monotonicity*: a vulnerability should never rank lower if it becomes more frequent or more damaging. Third, *limited compensation*: rare tail-loss events should not automatically dominate categories that recur persistently across the exploit record. Fourth, *boundedness and interpretability*: intermediate scores should remain auditable and easy to explain to developers and auditors. Fifth, *prospective validity*: the selected rule should be evaluated on future incidents rather than only reconstructed on the same data used to define it.

These requirements matter because familiar score operators encode different assumptions. Additive rules allow partial compensation. Bottleneck rules emphasize limiting conditions. Multiplicative rules emphasize interaction and none is justified by familiarity alone. We therefore keep only the score forms whose operators match the intended construct and remain useful under temporal holdout evaluation. Accordingly, multiplicative FMEA-style RPN is used only as an attack-level benchmark. AFS is used as an intermediate exploit-feasibility score after explicit comparison

Table 4

Attack-Level Baseline RPN Inputs and Values for the 2021–2023 Training Window

Attack Type	N_a	M_a (USD)	L_a	S_a	RPN_a
Reentrancy Attacks	35	1,700K	4	4	16
Bridge Exploits	8	17,900K	3	5	15
Flash Loan Attacks	86	133.5K	5	2	10
Oracle Manipulation	8	444.5K	3	3	9
External Call Abuse	18	112K	4	2	8
Governance Exploits	5	1,080K	2	4	8
Contract Logic Exploits	204	90K	5	1	5
Key Compromise	4	51,500K	1	5	5
MEV Attacks	3	241K	1	3	3
Composability Abuse	5	78K	2	1	2
Phishing Attacks	1	95K	1	1	1

among prevalence-and-accessibility combinations. The main Vulnerability-Centric Risk Score (VRS) is expressed as a structured ranking because no scalar alternative is strongest across both holdouts and both future targets while preserving the intended likelihood-first remediation semantics.

We evaluate ranking quality on two temporal holdouts. The primary *2024–2025 holdout* trains on 2021–2023 incidents and tests on the next two full years, which gives a larger future evaluation window and reduces sensitivity to idiosyncrasies in any single calendar year. The secondary *2025 holdout* trains on 2021–2024 incidents and tests only on 2025, which checks whether the ranking remains useful on the most recent year after being estimated on all earlier incidents. The validation workflow is therefore: (1) compute a score or ranking on the training window, (2) build the corresponding future ranking on the holdout window, and (3) compare the two orderings.

Our main comparison metric is Spearman rank correlation. Let R_i denote the rank assigned by the scoring method to class i , and let Q_i denote the corresponding future observed rank of that same class. Then

$$\rho_s = \frac{\sum_{i=1}^n (R_i - \bar{R})(Q_i - \bar{Q})}{\sqrt{\sum_{i=1}^n (R_i - \bar{R})^2} \sqrt{\sum_{i=1}^n (Q_i - \bar{Q})^2}},$$

with average ranks used when ties occur. A higher positive ρ_s means stronger agreement between the present score-induced ordering and the future observed ordering; values near 1 indicate strong forward-looking prioritization utility, values near 0 indicate little monotonic relationship, and negative values indicate that the method is ordering classes in the wrong direction. This prospective protocol therefore evaluates ordering quality rather than exact loss prediction or a universal notion of “true” risk.

The evaluation therefore answers three questions. First, *base empirical validity*: does the likelihood-and-severity ranking inferred from historical incidents align with future vulnerability importance? Second, *mapping contribution*: does adding the adversarial capability and knowledge mapping improve that ranking beyond the empirical base? Third, *operational usefulness*: does the final VRS ordering provide a clearer remediation sequence for auditors and protocol teams?

6.2. Risk Priority Number (RPN)

We keep RPN as a simplified FMEA-style baseline for attack-type ranking [25, 38, 39]. For each attack type a , let N_a be its training-window incident count and M_a its training-window median incident loss in USD. To make both dimensions explicit, we convert them into bounded five-level ordinal scores:

$$L_a = Q_5(N_a), \quad S_a = Q_5(M_a),$$

where $Q_5(\cdot)$ denotes a descending empirical quintile-style level on the 1–5 scale within the training window. The baseline RPN is then

$$RPN_a = L_a \times S_a.$$

This formulation is included because it captures the familiar intuition that categories that are jointly common and severe deserve attention. Here, severity refers to absolute economic loss rather than protocol-relative loss because the baseline is meant to summarize broad attack damage in a way that is measurable for the full dataset. We do not treat this multiplicative form as theoretically privileged. In the comparative score-family evaluation, multiplicative RPN is clearly weaker than simpler alternatives. On the 2024–2025 holdout, it achieved Spearman $\rho = 0.345$ against future attack counts and $\rho = 0.388$ against future total loss, compared with $\rho = 0.814/0.824$ for frequency-only, $\rho = 0.782/0.791$ for a likelihood-first lexicographic ordering, and $\rho = 0.791/0.801$ for the strongest continuous scalar attack alternative. On the 2025 holdout, the same pattern remained ($\rho = 0.128/0.128$ for multiplicative RPN versus $\rho = 0.720/0.720$ for frequency-only). We therefore use RPN only as an interpretable baseline rather than as the preferred attack-level scoring rule.

Table 4 reports the attack-baseline inputs and resulting RPN values for the 2021–2023 training window. Including these values explicitly makes the baseline auditable: readers can see the training-window incident counts, median-loss inputs, ordinal levels, and resulting RPNs rather than treating the baseline as an opaque formula.

This attack-level baseline and the later vulnerability-level ranking serve different purposes. RPN is valid as an ecosystem-monitoring view because attack types describe the observable manifestation of incidents and therefore support coarse trend comparison across years. But attack types are not always the best remediation unit: categories such as flash-loan attacks, bridge exploits, or oracle manipulation can bundle together heterogeneous underlying weaknesses, while the same vulnerability class can appear through different attack manifestations depending on protocol design. For that reason, we retain RPN as a transparent attack-centric benchmark and shift the main validated contribution to the vulnerability level, where prioritization aligns more directly with remediable root causes.

6.3. Adversarial Feasibility Score (AFS)

AFS is an exploit-feasibility construct rather than a second risk model. The central question is not “how much damage does a trait cause by itself?” but “how attainable does successful exploitation appear once a vulnerability class is implicated?”. Downstream damage is already captured in the empirical severity layer. Severity is therefore not part of AFS and enters later through VRS.

We use AFS at two related levels. Trait-level AFS_{*i*} quantifies the attainability of individual adversarial prerequisite traits. Vulnerability-level AFS_{*v*} aggregates those mapped trait scores to quantify the attainability of exploiting vulnerability class *v*. Only AFS_{*v*} enters the final VRS ordering. AFS_{*i*} is kept explicit mainly to make the threat-model contribution auditable.

6.3.1. Trait-Level AFS (AFS_{*i*})

For each adversarial trait *i*, let *s_i* denote its support rate in the training window, i.e., the share of training incidents whose mapped vulnerabilities require or strongly implicate that trait. We convert this empirical support rate into a bounded prevalence score

$$P_i = 1 + 4s_i.$$

This preserves a 1–5 interpretation while avoiding arbitrary hand-picked support-rate bands. We then define a bounded accessibility score $A_i \in \{1, \dots, 5\}$ from the threat model using four explicit barrier criteria. Let O_i , E_i , I_i , and B_i be binary indicators for whether trait *i* is publicly observable, externally attainable, independent of insider or validator privilege, and free of substantial capital, expertise, or coordination burden, respectively. We then set

$$A_i = 1 + O_i + E_i + I_i + B_i.$$

Operationally, $O_i = 1$ when the relevant information or capability is publicly visible by design or widely documented. $E_i = 1$ when an outside actor can attain it without insider relationships. $I_i = 1$ when it does not require protected authority such as validator, sequencer, or administrative control. $B_i = 1$ when it does not impose substantial capital, infrastructure, or coordination burden. Higher values therefore denote traits that are more broadly attainable from outside the protocol.

The trait-level combination is a design choice, so we do not treat any single formula as self-evident. During model development, we compared prevalence-only, accessibility-only, weighted averages, geometric means, harmonic means, bottleneck minima, and raw products by asking which formulations most improved the final vulnerability ordering on future incidents. No combined prevalence-plus-accessibility family dominated on both holdouts. In the comparative

Table 5Trait-Level AFS_i Components and Scores for the 2021–2023 Training Window

Trait	P_i	O_i	E_i	I_i	B_i	A_i	AFS_i
AK_1	3.96	1	1	1	1	5	4.45
AK_2	2.40	1	1	1	1	5	3.46
AK_3	2.18	1	1	1	0	4	2.95
AK_4	3.96	1	1	1	0	4	3.98
AK_5	1.06	1	1	1	0	4	2.06
AK_6	2.31	0	0	1	0	2	2.15
AK_7	2.05	0	0	0	0	1	1.43
AC_1	3.98	1	1	1	0	4	3.99
AC_2	1.00	0	0	0	0	1	1.00
AC_3	2.00	1	1	1	0	4	2.83
AC_4	2.01	0	0	0	0	1	1.42
AC_5	2.73	1	1	1	0	4	3.30

evaluation, several non-product forms — equal mean, geometric mean, harmonic mean, prevalence-weighted means, and bottleneck minimum — collapse to essentially the same vulnerability ordering, whereas the raw product is weaker. We therefore use the geometric mean because it is the cleanest scale-preserving interaction: it uses both ingredients directly, avoids arbitrary linear weights, stays on the original 1–5 scale, and does not impose the stronger claim that one side must always dominate the other. The trait-level feasibility score is

$$AFS_i = \sqrt{P_i A_i}.$$

This formulation should therefore be read as a justified design choice, not as a claim that multiplicative interaction is uniquely correct.

Table 5 reports the resulting trait-level values for the main 2021–2023 training window, including the binary accessibility criteria used to derive A_i . These are not final vulnerability-priority scores. Their purpose is to make the threat-model contribution auditable: the table shows how each trait satisfies the four barrier criteria, which traits are both recurrent and broadly attainable, and which remain constrained because they are rare, privileged, or operationally burdensome.

6.3.2. Vulnerability-Level AFS (AFS_v)

We next map the trait-level feasibility scores to vulnerabilities. Let $C(v)$ denote the mapped capability-side traits for vulnerability v and let $K(v)$ denote the mapped knowledge-side traits. We first aggregate within each prerequisite family:

$$AFS_v^{cap} = \min_{c \in C(v)} AFS_c, \quad AFS_v^{know} = \min_{k \in K(v)} AFS_k,$$

$$AFS_v^{(w)} = w AFS_v^{cap} + (1 - w) AFS_v^{know},$$

where the minima provide a conservative bottleneck approximation at this mapping stage. They emphasize the most restrictive mapped capability and knowledge conditions associated with a vulnerability class, without claiming that every exploit instance requires all listed traits in exactly the same way. We then treat the final capability/knowledge blend as a candidate family rather than assuming a privileged 50/50 weighting a priori. A dedicated sensitivity sweep over $w \in \{0, 0.1, \dots, 1\}$ shows a clear pattern: knowledge-heavy blends are consistently weaker, while balanced-to-capability-leaning blends perform best across the two temporal holdouts. No single weight dominates every metric. The main holdout favors a mildly capability-leaning blend ($w = 0.6$), whereas the 2025 holdout attains its strongest future-count result at the symmetric midpoint and its strongest future-loss result under more capability-heavy settings. We therefore use the symmetric midpoint

$$AFS_v = AFS_v^{(0.5)} = \frac{AFS_v^{cap} + AFS_v^{know}}{2},$$

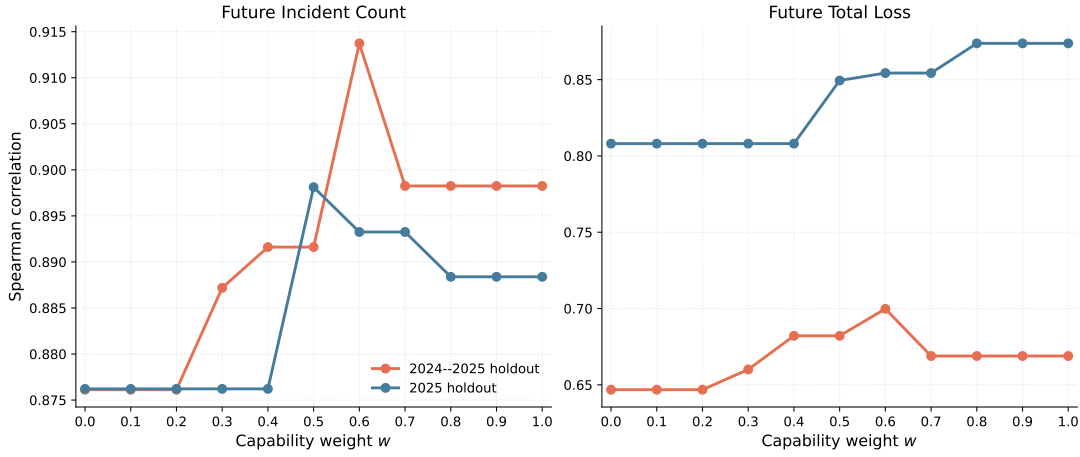


Figure 4: Sensitivity of the vulnerability-level AFS to the capability/knowledge blend weight w . For each value of w , the combined score is $AFS_v^{(w)} = w AFS_v^{cap} + (1 - w) AFS_v^{know}$. The sweep favors balanced-to-capability-leaning blends over knowledge-heavy ones; the midpoint $w = 0.5$ is used as the strongest symmetric choice and the cleanest entry point into the high-performing region.

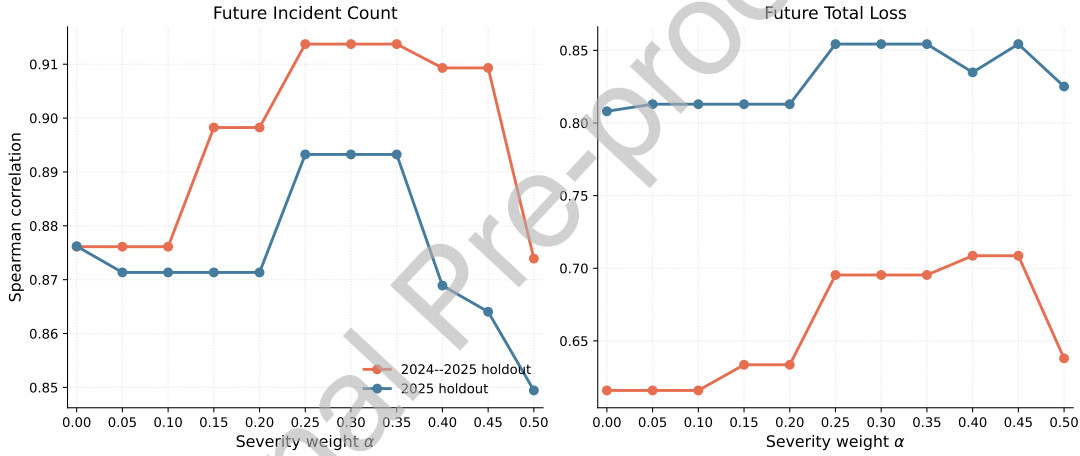


Figure 5: Sensitivity of the final VRS ordering to the secondary severity/AFS blend used within each likelihood level. For each severity weight α , the refinement score is defined as $C_v^{(\alpha)} = \alpha S_v + (1 - \alpha) AFS_v$, while likelihood L_v remains the primary ordering dimension and $S_v = Q_5(M_v)$ is already on the same 1–5 scale as AFS_v . The chosen value $\alpha = 0.3$ lies inside the strongest balanced region on both temporal holdouts while preserving strong future-count performance.

because it is the strongest balanced choice. It lies at the onset of the high-performing region in both holdouts, preserves symmetry between the two prerequisite families, and avoids post hoc tuning toward any single target metric. Figure 4 shows the midpoint as the cleanest symmetric entry point into the strongest region of the sweep.

A trait-level AFS_i near 1 denotes a prerequisite that is either historically uncommon, strongly access-constrained, or both. Values near 5 denote prerequisites that are both recurrent in the incident record and broadly attainable. The vulnerability-level AFS_v inherits this interpretation conservatively: low values indicate that at least one mapped bottleneck remains restrictive, while higher values indicate vulnerability classes whose mapped exploit prerequisites are comparatively attainable. In this sense, AFS_v is the actual vulnerability-level feasibility score that later refines VRS, whereas AFS_i is the auditable trait-level building block from which it is derived.

6.4. Vulnerability-Centric Risk Score (VRS)

We define VRS as the paper’s main structured vulnerability-priority ranking. For each vulnerability v , let N_v be the number of training incidents mapped to v and let M_v be the median USD loss across those incidents. We use the median instead of the mean because DeFi losses are highly heavy-tailed. A few catastrophic bridge or key-compromise events can dominate averages, obscure the central severity profile of frequently recurring vulnerability classes, and make

category-level severity sensitive to a small number of extreme rows. In this setting, M_v is intended to capture the typical economic severity conditional on that vulnerability class occurring, not the single worst historical outlier. It therefore captures economic severity, not protocol-relative severity.

To make both likelihood and severity explicit, we convert these empirical quantities into bounded ordinal levels:

$$L_v = Q_4(N_v), \quad S_v = Q_5(M_v),$$

where $Q_4(\cdot)$ denotes a descending empirical quartile-style level on the 1–4 scale and $Q_5(\cdot)$ denotes a descending empirical quintile-style level on the 1–5 scale. We use these bounded empirical levels as interpretable discretizations rather than as a claim that the cutoffs have intrinsic theoretical meaning. The likelihood side remains on four levels because the vulnerability universe is compact. The severity side is placed directly on the same 1–5 scale as AFS_v , so the secondary refinement can be combined without an additional rescaling step.

Likelihood is the primary dimension in the VRS method. This is intentional: VRS is meant for forward-looking remediation prioritization, and vulnerability classes that recur persistently across incidents represent broader reusable ecosystem exposure than equally severe but much rarer classes. Our baseline comparisons and temporal sensitivity analyses corroborate this design choice by showing that likelihood-dominant variants remain much stronger than severity-dominant alternatives on future data.

To refine the ordering within each likelihood level, we combine severity and adversarial feasibility. Because $S_v = Q_5(M_v)$ is already on the same 1–5 scale as AFS_v , the secondary refinement family can be written directly as

$$C_v^{(\alpha)} = \alpha S_v + (1 - \alpha) AFS_v,$$

where α controls how much within-likelihood ordering is driven by severity rather than feasibility. Figure 5 shows the corresponding sensitivity analysis. The values $\alpha = 0.25$ through $\alpha = 0.35$ form the strongest balanced plateau across the two temporal holdouts. We retain $\alpha = 0.3$ as a central point in that region because it preserves the intended likelihood-first semantics while keeping severity materially present in the within-likelihood refinement.

The final VRS ordering is therefore defined lexicographically by descending

$$(L_v, C_v^{(0.3)}, S_v, AFS_v, N_v, M_v).$$

This means: compare likelihood level first, then compare the severity/AFS refinement score, then use the remaining empirical quantities only as tie-breakers. For comparison only, the simpler empirical baseline is the lexicographic order (L_v, S_v, N_v, M_v) . This formulation keeps the method structured rather than forcing it into a single scalar law, while still making all three ingredients explicit. In the comparative score-family evaluation, direct scalar alternatives remain competitive. On the larger 2024–2025 holdout, an additive scalar reaches $\rho = 0.903$ against future counts and $\rho = 0.801$ against future total loss. On the 2025 holdout, a weighted scalar reaches $\rho = 0.864$ against future counts and $\rho = 0.898$ against future total loss. The structured VRS reaches $\rho = 0.914$ against future counts and $\rho = 0.695$ against future total loss on the larger holdout, and $\rho = 0.893$ and $\rho = 0.854$ on the 2025 holdout. We retain it on interpretability grounds: no scalar alternative is strongest across both holdouts and both future targets while preserving the intended likelihood-first remediation semantics, and the structured rule still improves on the empirical base rank across both future targets.

One concrete example from Table 7 shows how this ordering works. Oracle Trust Assumptions ($\mathbb{PL}_1$) and Liquidity Manipulation Susceptibility ($\mathbb{PL}_2$) both lie in the top likelihood level ($L_v = 4$), and under the retained $Q_5(M_v)$ severity definition they also share the same severity level ($S_v = 3$). The next comparison is therefore the secondary score C_v . Because $\mathbb{PL}_2$ has a slightly higher feasibility score ($AFS_v = 2.18$ versus 2.13), its combined score rises to 2.43, above $\mathbb{PL}_1$ at 2.39, so it ranks higher in the final VRS ordering. This example is representative of the rule: likelihood determines the macro-ordering, while severity and feasibility jointly refine the order within each likelihood level.

Table 6 translates the associated priority tiers into typical remediation postures for protocol teams and auditors. These tiers are derived from the final VRS ordering itself by partitioning the ranked list into four contiguous quartile-like groups, so they remain presentation tiers rather than hidden computational inputs. Table 7 shows the resulting VRS ordering for the 2021–2023 training window. Smart-contract-layer failures dominate the highest-priority tier, while bridge-specific cross-chain verification failures ($\mathbb{PL}_5$) remain in the upper half of the ranking despite lower frequency because their severity profile is catastrophic when they occur.

Table 6

Operational Interpretation of VRS Priority Tiers

Tier	Typical meaning and action
P1	Immediate audit and remediation target. Protocol teams should review privileged control paths, pricing assumptions, and invariant boundaries before feature expansion, while auditors should prioritize deep manual review and adversarial scenario testing.
P2	Near-term hardening target. Protocol teams should schedule focused architecture review and extend regression, invariant, and integration tests, while auditors should run targeted review of economic assumptions and external-call surfaces.
P3	Scheduled mitigation and monitoring target. Protocol teams should add monitoring and dependency review, while auditors should keep the category in routine review cycles and scoped follow-up assessments.
P4	Lower observed urgency, but still included in threat modeling. Protocol teams should preserve coverage in checklists and continuous-integration tests, and auditors should revisit the category when protocol architecture or trust assumptions change.

Table 7

Structured VRS Ordering for the 2021–2023 Training Window

Vulnerability	N_v	M_v (USD)	L_v	S_v	AFS_v	C_v	Tier	Final Rank
Arithmetic Faults (SCL_2)	154	78K	4	1	3.98	3.09	P1	1
Improper Access Control (SCL_5)	67	65K	4	1	3.98	3.09	P1	2
Liquidity Manipulation Susceptibility (PL_2)	83	111K	4	3	2.18	2.43	P1	3
Oracle Trust Assumptions (PL_1)	74	133.5K	4	3	2.13	2.39	P1	4
Unchecked External Calls (SCL_3)	19	120K	3	3	3.98	3.69	P2	5
Reentrancy Conditions (SCL_1)	35	1,700K	3	5	2.73	3.41	P2	6
Unsafe Delegatecall Use (SCL_4)	14	94.5K	3	2	3.64	3.15	P2	7
Cross-Chain State Verification Assumptions (PL_5)	5	80,000K	2	5	2.37	3.16	P3	8
Off-Chain Oracle Dependence (ASL_1)	9	888K	2	4	2.13	2.69	P3	9
Governance Design Flaws (PL_4)	5	1,080K	2	4	1.74	2.42	P3	10
Composability Risk (PL_3)	10	86K	2	2	2.37	2.26	P3	11
Transaction Reordering in Block Construction (CL_3)	3	241K	1	4	2.73	3.11	P4	12
Credential Exposure (ASL_2)	4	51,500K	1	5	1.43	2.50	P4	13
Phishing-Prone Interfaces (ASL_3)	1	95K	1	2	2.37	2.26	P4	14

6.5. Prospective Utility Evaluation

The out-of-sample validation results show that the final structured VRS ordering is much stronger than the multiplicative baseline and that the retained severity weight improves the loss side while preserving strong performance on future-count ranking. On the 2024–2025 holdout, the final VRS ordering improves the Spearman correlation for future counts over both the empirical base rank (0.914 versus 0.867) and the frequency-only comparator (0.914 versus 0.854). It also improves the ranking by future total loss over both the base rank (0.695 versus 0.673) and frequency-only (0.695 versus 0.681). On the 2025 holdout, the final VRS again improves on the empirical base rank for both ranking by future counts (0.893 versus 0.849) and ranking by future total loss (0.854 versus 0.825). Frequency-only remains slightly stronger on both 2025-only targets (0.897 versus 0.893 for future counts and 0.873 versus 0.854 for future total loss). The resulting likelihood-first secondary-blend rule is therefore best read as a balanced prioritization rule.

The mapping ablation is also informative. On the 2024–2025 holdout, adding capability-side refinement raises the Spearman correlation for future counts from 0.867 to 0.898, adding knowledge-side refinement raises it to 0.876, and the combined AFS refinement reaches 0.914. For ranking by future total loss on that same holdout, the combined refinement also improves on the empirical base rank (0.695 versus 0.673), although capability-only and knowledge-only variants remain weaker at 0.669 and 0.647. On the 2025 holdout, capability-only refinement reaches $\rho = 0.888$ against future counts and $\rho = 0.874$ against future total loss, while the combined AFS refinement reaches $\rho = 0.893$ and $\rho = 0.854$. Thus, the mapping layer contributes positively on both temporal holdouts, but the best capability/knowledge combination still depends on the target. The combined refinement is strongest for future-count ordering on the larger holdout, while capability-side refinement remains strongest among the mapped variants for future-loss ranking in the



Figure 6: Out-of-sample validation comparison across the main vulnerability-ranking methods. The left panel reports Spearman correlation against future vulnerability counts, and the right panel reports Spearman correlation against future total loss. Within each panel, grouped horizontal bars compare the 2024–2025 holdout (train 2021–2023) and the 2025 holdout (train 2021–2024), and the numeric labels report the exact correlation values.

2025 holdout. Figure 5 makes the within-likelihood weighting choice explicit. We use $\alpha = 0.3$ because it lies at the center of the best balanced region while keeping future-count performance strong.

Because the validation universe contains only a small number of vulnerability classes, we complement the point estimates with a non-parametric label-level bootstrap stability analysis (10,000 resamples with replacement over the ranked class set). The resulting deltas support a balanced interpretation. On the 2024–2025 holdout, the gain over the base rank is +0.046 for the Spearman correlation against future counts (95% CI $[-0.012, 0.099]$, positive share 0.944) and +0.022 for the Spearman correlation against future total loss (95% CI $[-0.117, 0.129]$, positive share 0.622). Relative to frequency-only on that same holdout, the corresponding deltas are +0.060 and +0.015. On the 2025 holdout, the final-minus-base deltas are +0.044 for future counts and +0.029 for future total loss, while the final-minus-frequency deltas are slightly negative for future counts (-0.004) and future total loss (-0.018). The percentile intervals remain wide and mostly straddle zero, so we interpret this resampling analysis as a heuristic robustness check rather than as a formal significance test. This is appropriate because the temporal evaluation is conducted over a compact set of vulnerability classes rather than thousands of independent observations.

We also complement the main method with auxiliary likelihood/severity weighting checks (not shown) over the empirical base ordering. Those auxiliary runs showed that likelihood-dominant variants remain much stronger than severity-dominant alternatives on both temporal holdouts, which is why VRS keeps recurrence as the primary ordering dimension even after severity and AFS are made explicit in the secondary score.

Figure 6 consolidates the comparative out-of-sample results into two grouped bar charts: one for future-count ranking and one for future-loss ranking. Each panel shows both temporal holdouts on the same axis, making it easier to compare the main candidate methods directly and to see where VRS improves on the empirical base rank and where simpler baselines remain competitive.

Viewed through the three evaluation questions above, the results have a clear interpretation. First, the base empirical rank already captures meaningful forward-looking signal while preserving both likelihood and severity explicitly. It remains far above multiplicative and severity-dominant baselines on both temporal holdouts, even though frequency-only remains a strong comparator and some direct scalar variants are competitive on individual targets. Second, the threat-model mapping adds measurable value on both temporal holdouts once severity receives a modest but nontrivial within-likelihood role: the Spearman correlation against future counts rises from 0.867 under the base empirical rank to 0.914 under the final VRS ordering on the 2024–2025 holdout and from 0.849 to 0.893 on the 2025 holdout, while the Spearman correlation against future total loss rises from 0.673 to 0.695 and from 0.825 to 0.854, respectively. Third, the final VRS output is not intended as an abstract scalar notion of “true risk.” It is a structured remediation-ordering

score. It identifies which vulnerability classes should be examined first because they combine historical recurrence, historical economic severity, and comparatively attainable exploitation conditions.

The scientific grounding of the framework rests on two components. Conceptually, each representation matches a narrower and more explicit construct: RPN is an attack-level FMEA baseline, AFS is an intermediate feasibility score selected from a candidate family rather than assumed a priori, and VRS is the main structured prioritization output. Empirically, these forms are justified prospectively rather than only reconstructed in-sample. This makes the framework better suited for operational prioritization than a single scalar product while still preserving an interpretable relationship to established FMEA-style baselines.

7. Discussion

DeFi security work has improved substantially, but vulnerability prioritization remains less developed than vulnerability discovery. Many platforms still rely on reactive defenses rather than methods that help order likely exploit pathways before they are triggered. Current threat models also tend to focus on single attack vectors, even though real incidents often combine multiple techniques across layers.

Methodologically, an additional lesson from this study is that severity in DeFi has more than one legitimate interpretation. Absolute economic loss captures broad ecosystem severity and is consistently measurable across historical incidents, whereas TVL-normalized loss captures relative protocol impact but depends on denominators that are often incomplete or non-comparable in retrospective exploit reporting. For that reason, the main framework in this paper uses absolute-loss severity, while protocol-size-normalized sensitivity analysis is treated as a supplementary extension rather than a required precondition for risk ranking.

7.1. Limitations

Several limitations should frame the interpretation of the results. First, the incident corpus is the result of mixed-provenance curation rather than uniform case-by-case manual reconciliation of every row. The dataset contains targeted curator review for high-loss, taxonomy-sensitive, and ambiguous incidents, but some included rows still inherit seed-stage labels from the primary incident repository. The resulting rankings are therefore informative, but they remain sensitive to row-level relabeling when important incidents move between vulnerability classes.

Second, the empirical corpus is necessarily retrospective. It is built from discovered and publicly documented incidents, so it may underrepresent silent value leakage, long-horizon malicious extraction, or severe design flaws that were feasible but not yet triggered under historical market conditions. The resulting rankings are therefore best read as forward-looking prioritization over the observed exploit record, not as exhaustive coverage of every latent DeFi failure mode. In practice, the framework is better at prioritizing historically manifested vulnerability classes than entirely novel exploit forms.

Third, the empirical validation universe is compact. Although the taxonomy defines 16 vulnerability classes, only 14 appear in the included incident dataset and therefore enter the temporal ranking experiments. This is why the paper supplements point estimates with a bootstrap stability check and interprets those intervals cautiously. The validation results should therefore be read as evidence of forward-looking prioritization utility over a compact ranked class set, not as a large-sample significance result.

Fourth, the taxonomy still has edge cases. Incidents such as Euler-style insolvency or business-logic failures do not always fit neatly into the current vulnerability vocabulary, even after case-level audit. The framework is therefore best understood as a practically useful taxonomy with visible boundary cases, rather than a claim that every DeFi exploit can be classified without residual ambiguity.

Fifth, the retained VRS is a balanced prioritization rule rather than a universal winner on every target. It improves on the empirical base rank across both temporal holdouts and both future targets, but frequency-only and some scalar variants remain competitive, especially on future-loss ranking. We nevertheless retain VRS because it serves a broader operational purpose than frequency alone: it keeps severity and attacker-feasibility visible in the same remediation-ordering rule, which is useful for audit triage even when simple baselines remain competitive on a single predictive target. Likewise, the main model uses absolute-loss severity because it is consistently measurable across the full historical corpus, whereas TVL-normalized severity is only available on a better-curated subset.

7.2. Future Work

An important next step is to extend the present temporal validation rather than stop at it. This paper already evaluates the ranking framework on held-out future incidents, but additional validation could use longer horizons, alternative

protocol subsets, and scenario-based stress tests. Such follow-on evaluation would help determine whether the scoring system captures enduring structural risks rather than only the historical regularities observed between 2021 and 2025. A parallel methodological extension is broader protocol-size-normalized sensitivity analysis on the subset of incidents for which defensible historical TVL denominators can be recovered.

Additional future work should also refine the taxonomy itself. Business-logic insolvency failures, cross-protocol accounting breakdowns, and other edge-case events suggest that the current vulnerability set can be extended further. A next iteration of the framework could pair targeted taxonomy expansion with external validation on alternative incident sources and protocol subsets, making it possible to test whether the current rankings remain stable under broader curation regimes. This is especially relevant for bridge systems and other multi-chain dependencies, where failure modes remain severe even when they are infrequent.

Finally, operational deployment would benefit from tighter integration with defense tooling. Real-time monitoring, invariant testing, and scenario-based security analysis could all be informed by the current rankings, especially if future versions of the framework are paired with automated exploit detection pipelines and protocol-specific telemetry. These steps would move the framework closer to an operational risk-prioritization workflow.

8. Conclusion

This paper introduced a layered vulnerability-prioritization framework for decentralized finance (DeFi), built from three complementary components: a baseline Risk Priority Number (RPN), a feasibility-oriented Adversarial Feasibility Score (AFS), and a structured Vulnerability-Centric Risk Score (VRS). Grounded in a dataset of 558 incidents from 2021–2025, the framework provides a systematic way to evaluate attack frequency, absolute economic severity, adversarial capabilities, and underlying vulnerabilities across smart contract, protocol, auxiliary service, and consensus layers.

Our contributions are threefold. First, we develop a DeFi infrastructure taxonomy in which DeFi-native mechanisms such as liquidity dependence, governance manipulability, composability, and cross-chain verification assumptions are represented explicitly rather than absorbed into a generic blockchain stack. Second, we introduce a feasibility score that maps vulnerabilities to concrete adversarial prerequisites through bounded prevalence and accessibility signals, allowing attacker attainability to inform prioritization without being conflated with downstream severity. Third, we evaluate alternative ranking rules on temporal train/test splits and show that a likelihood-first vulnerability-priority method, refined by adversarial feasibility, outperforms multiplicative attack baselines and improves on the empirical base rank across both holdouts, while remaining more interpretable than direct scalar vulnerability scores.

This work advances the methodological basis for DeFi vulnerability prioritization and offers a transparent basis for researchers, auditors, and protocol designers. The framework is intentionally conservative in its claims: RPN serves as an interpretable FMEA-style benchmark, AFS serves as an intermediate feasibility score rather than a universal law, and VRS serves as a validated structured ranking rather than a direct product. The main validated model uses absolute-loss severity because it is consistently measurable across the full incident dataset, while protocol-size-normalized TVL analysis is reserved for supplementary sensitivity work where denominator quality can be defended. Future work will focus on broader validation, protocol-size-normalized sensitivity analysis, scenario stress testing, and integration with automated security auditing pipelines.

Author Contribution Statement

All authors meet Elsevier's authorship criteria. Each author contributed substantially to the conception, execution, and writing of this study:

- Sanidhay Arora: Conceptualization, Methodology, Data Curation, Software, Validation, Formal Analysis, Writing – Original Draft, Writing – Review & Editing.
 - Yebo Feng: Methodology, Formal Analysis, Investigation, Writing – Review & Editing.
 - Jiahua Xu: Conceptualization, Validation, Supervision, Writing – Review & Editing.
 - Yingjiu Li: Conceptualization, Supervision, Project Administration, Writing – Review & Editing.
- All authors approved the final manuscript and agree to be accountable for all aspects of the work.

Declaration of Interest Statement

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Declaration of Generative AI Use

During the preparation of this work, the authors used DeepSeek AI and Codex tools to implement code and improve grammar. After using these tools and services, the authors reviewed and edited the content as needed and take full responsibility for the content of the publication.

References

- [1] C. R. Harvey, A. Ramachandran, and J. Santoro, *DeFi and the Future of Finance*. John Wiley & Sons, 2021.
- [2] S. Werner, D. Perez, L. Gudgeon, A. Klages-Mundt, D. Harz, and W. Knottenbelt, “SoK: Decentralized finance (DeFi),” in *Proceedings of the 4th ACM Conference on Advances in Financial Technologies*, 2022, pp. 30–46.
- [3] F. Bekemeier, “Deceptive assurance? a conceptual view on systemic risk in decentralized finance (DeFi),” in *Proceedings of the 2021 4th International Conference on Blockchain Technology and Applications*, ser. ICBTA ’21. New York, NY, USA: Association for Computing Machinery, 2022, p. 76–87. [Online]. Available: <https://doi.org/10.1145/3510487.3510499>
- [4] W. Li, J. Bu, X. Li, H. Peng, Y. Niu, and Y. Zhang, “A survey of DeFi security: challenges and opportunities,” *Journal of King Saud University - Computer and Information Sciences*, vol. 34, no. 10, pp. 10 378–10 404, 2022.
- [5] L. Zhou, X. Xiong, J. Ernstberger, S. Chaliasos, Z. Wang, Y. Wang, K. Qin, R. Wattenhofer, D. Song, and A. Gervais, “SoK: Decentralized finance (DeFi) attacks,” in *2023 IEEE Symposium on Security and Privacy (SP)*. IEEE, 2023, pp. 2444–2461.
- [6] S. Chaliasos, M. A. Charalambous, L. Zhou, R. Galanopoulou, A. Gervais, D. Mitropoulos, and B. Livshits, “Smart contract and DeFi security: insights from tool evaluations and practitioner surveys,” *arXiv preprint arXiv:2304.02981*, 2023.
- [7] Y. Ding, A. Gervais, R. Wattenhofer, and H. Sato, “Hunting DeFi vulnerabilities via context-sensitive concolic verification,” *arXiv preprint arXiv:2404.10376*, 2024.
- [8] K. Qin, L. Zhou, B. Livshits, and A. Gervais, “Attacking the DeFi ecosystem with flash loans for fun and profit,” in *International conference on financial cryptography and data security*. Springer, 2021, pp. 3–32.
- [9] SunWeb3Sec, “DeFi Hack Labs,” <https://github.com/SunWeb3Sec/DeFiHackLabs>, 2024.
- [10] FIRST, “rekt leaderboard,” 2025. [Online]. Available: <https://rekt.news/leaderboard>
- [11] SlowMist. (2024) Slowmist hacks list. [Online]. Available: <https://hacked.slowmist.io/>
- [12] J. Xu, Y. Feng, D. Perez, and B. Livshits, “Auto.gov: Learning-based governance for decentralized finance (defi),” *IEEE Transactions on Services Computing*, vol. 18, no. 3, pp. 1278–1292, 2025.
- [13] L. Gudgeon, S. Werner, D. Perez, and W. J. Knottenbelt, “Defi protocols for loanable funds: Interest rates, liquidity and market efficiency,” in *Proceedings of the 2nd ACM Conference on Advances in Financial Technologies*, ser. AFT ’20. New York, NY, USA: Association for Computing Machinery, 2020, p. 92–112. [Online]. Available: <https://doi.org/10.1145/3419614.3423254>
- [14] Z. Chen, S. M. Beillahi, and F. Long, “Flashsyn: Flash loan attack synthesis via counter example driven approximation,” in *Proceedings of the IEEE/ACM 46th International Conference on Software Engineering*, 2024, pp. 1–13.
- [15] B. Wang, X. Yuan, L. Duan, H. Ma, C. Su, and W. Wang, “DeFiScanner: spotting DeFi attacks exploiting logic vulnerabilities on blockchain,” *IEEE Transactions on Computational Social Systems*, 2022.
- [16] S. Wu, D. Wang, J. He, Y. Zhou, L. Wu, X. Yuan, Q. He, and K. Ren, “DeFiRanger: detecting price manipulation attacks on DeFi applications,” *CoRR*, vol. abs/2104.15068, 2021. [Online]. Available: <https://arxiv.org/abs/2104.15068>
- [17] Y. Zhao, X. Kang, T. Li, C.-K. Chu, and H. Wang, “Toward trustworthy DeFi oracles: past, present, and future,” *IEEE Access*, vol. 10, pp. 60 914–60 928, 2022.
- [18] X. Deng, S. M. Beillahi, C. Minwalla, H. Du, A. Veneris, and F. Long, “Safeguarding DeFi smart contracts against oracle deviations,” in *Proceedings of the IEEE/ACM 46th International Conference on Software Engineering*, 2024, pp. 1–12.
- [19] N. Carter and L. Jeng, “DeFi protocol risks: the paradox of DeFi,” *Regtech, supotech and beyond: innovation and technology in financial services* riskbooks–forthcoming Q, vol. 3, 2021.
- [20] S. Kitzler, F. Victor, P. Saggese, and B. Haslhofer, “Disentangling decentralized finance (DeFi) compositions,” *ACM Trans. Web*, vol. 17, no. 2, mar 2023. [Online]. Available: <https://doi.org/10.1145/3532857>
- [21] A. Klages-Mundt, D. Harz, L. Gudgeon, J.-Y. Liu, and A. Minca, “Stablecoins 2.0: Economic foundations and risk-based models,” in *Proceedings of the 2nd ACM Conference on Advances in Financial Technologies*, ser. AFT ’20. New York, NY, USA: Association for Computing Machinery, 2020, p. 59–79. [Online]. Available: <https://doi.org/10.1145/3419614.3423261>
- [22] Z. Wang, K. Qin, D. V. Minh, and A. Gervais, “Speculative multipliers on DeFi: quantifying on-chain leverage risks,” in *Financial Cryptography and Data Security*, I. Eyal and J. Garay, Eds. Cham: Springer International Publishing, 2022, pp. 38–56.
- [23] K. Qin, L. Zhou, P. Gamito, P. Jovanovic, and A. Gervais, “An empirical study of DeFi liquidations: incentives, risks, and instabilities,” in *Proceedings of the 21st ACM Internet Measurement Conference*, ser. IMC ’21. New York, NY, USA: Association for Computing Machinery, 2021, p. 336–350. [Online]. Available: <https://doi.org/10.1145/3487552.3487811>
- [24] J. Millionis, C. C. Moallemi, T. Roughgarden, and A. L. Zhang, “Quantifying loss in automated market makers,” in *Proceedings of the 2022 ACM CCS Workshop on Decentralized Finance and Security*, ser. DeFi’22. New York, NY, USA: Association for Computing Machinery, 2022, p. 71–74. [Online]. Available: <https://doi.org/10.1145/3560832.3563441>

- [25] S. El-Awady, "Overview of failure mode and effects analysis (FMEA): a patient safety tool," *Global Journal on Quality and Safety in Healthcare*, vol. 6, pp. 24–26, 2023.
- [26] D. Stamatis, "Failure mode and effect analysis: FMEA from theory to execution," *ASQ Quality Press*, 2003.
- [27] FIRST Organization, "Common Vulnerability Scoring System (CVSS) v3.1: Specification Document," <https://www.first.org/cvss/>, 2019, <https://www.first.org/cvss/specification-document>.
- [28] T. Schwarz and V. Patel, "Reconsidering CVSS: on the limitations of ordinal-based risk scoring," in *Proceedings of the 31st USENIX Security Symposium*. USENIX Association, 2022.
- [29] S. Kaur, S. Singh, S. Gupta, and S. Wats, "Risk analysis in decentralized finance (DeFi): a fuzzy-AHP approach," *Risk Management*, vol. 25, no. 2, p. 13, 2023.
- [30] J. Bertomeu, X. Martin, and I. Sall, "Measuring DeFi risk," *Finance Research Letters*, vol. 63, p. 105321, 2024.
- [31] K. Babel, M. Javaheripi, Y. Ji, M. Kelkar, F. Koushanfar, and A. Juels, "Lanturn: Measuring economic security of smart contracts through adaptive learning," in *Proceedings of the 2023 ACM SIGSAC Conference on Computer and Communications Security*, ser. CCS '23. New York, NY, USA: Association for Computing Machinery, 2023, p. 1212–1226. [Online]. Available: <https://doi.org/10.1145/3576915.3623204>
- [32] W. Li, J. Bu, X. Li, and X. Chen, "Security analysis of DeFi: vulnerabilities, attacks and advances," in *2022 IEEE International Conference on Blockchain (Blockchain)*. IEEE, 2022, pp. 488–493.
- [33] K. Gogol, C. Killer, M. Schlosser, T. Bocek, B. Stiller, and C. Tessone, "SoK: decentralized finance (DeFi)–fundamentals, taxonomy and risks," *arXiv preprint arXiv:2404.11281*, 2024.
- [34] N. Ivanov, C. Li, Q. Yan, Z. Sun, Z. Cao, and X. Luo, "Security threat mitigation for smart contracts: A comprehensive survey," *ACM Comput. Surv.*, vol. 55, no. 14s, jul 2023. [Online]. Available: <https://doi.org/10.1145/3593293>
- [35] T. A. Xu and J. Xu, "A short survey on business models of decentralized finance (DeFi) protocols," in *International Conference on Financial Cryptography and Data Security*. Springer, 2022, pp. 197–206.
- [36] Z. Li, B. Xiao, S. Guo, and Y. Yang, "Securing deployed smart contracts and DeFi with distributed TEE cluster," *IEEE Transactions on Parallel and Distributed Systems*, vol. 34, no. 03, pp. 828–842, mar 2023.
- [37] S. Arora, Y. Li, Y. Feng, and J. Xu, "SecPLF: Secure Protocols for Loanable Funds against Oracle Manipulation Attacks," in *19th ACM Asia Conference on Computer and Communications Security*, vol. 12. New York, NY, USA: ACM, 7 2024, pp. 1394–1405. [Online]. Available: <http://arxiv.org/abs/2401.08520>
- [38] J. Oliveira, G. Carvalho, B. Cabral, and J. Bernardino, "Failure mode and effect analysis for cyber-physical systems," *Future Internet*, vol. 12, no. 11, p. 205, 2020.
- [39] J. Haseeb, M. Mansoori, and I. Welch, "Failure modes and effects analysis (fmea) of honeypot-based cybersecurity experiment for iot," in *46th IEEE Conference on Local Computer Networks (LCN)*. IEEE, 2021, pp. 645–648.